

LAB TEST-4

AI ASISSTED CODING

NAME:MD.SANIYA

ROLL NO:2403A510E7

BATCH:05

Explain and develop a secure backend integration for an online payment system using the Razorpay API.

- (a) Write the secure API integration logic for order creation, payment verification, and webhook handling.
- (b) Add AI-recommended security enhancements, including strong encryption (such as AES-256-GCM) and secure token handling using short-lived access tokens and rotating refresh tokens.

Include code examples, security best practices, and architectural explanation.

CODE EXECUTED :

```

1 import razorpay
2 import json
3 from hashlib import sha256
4 import hmac
5 import os # Recommended for secure handling of environment variables
6
7 # --- 1. CONFIGURATION ---
8 # IMPORTANT: Use environment variables in production for security.
9 # Example:
10 # KEY_ID = os.environ.get("RAZORPAY_KEY_ID")
11 # KEY_SECRET = os.environ.get("RAZORPAY_KEY_SECRET")
12
13 KEY_ID = "YOUR_KEY_ID" # Replace with your actual Key ID
14 KEY_SECRET = "YOUR_KEY_SECRET" # Replace with your actual Key Secret
15
16 try:
17     # Initialize the Razorpay Client
18     client = razorpay.Client(auth=(KEY_ID, KEY_SECRET))
19     print("Razorpay Client Initialized.")
20 except Exception as e:
21     print(f"Error initializing Razorpay client. Check your keys: {e}")
22     # In a real app, you would log this and stop the process if critical.
23
24 # --- 2. ORDER CREATION FUNCTION (Backend API endpoint) ---
25 def create_razorpay_order(amount_in_rupees, currency="INR", receipt_id="receipt_order_001"):
26     """
27     Creates an Order object on the Razorpay server.
28
29     :param amount_in_rupees: The amount of the transaction in Rupees (e.g., 500.00)
30     :param currency: The currency code (default 'INR')
31     :param receipt_id: A unique ID for your internal tracking
32     :return: The Razorpay order object or None on error
33     """
34     # Razorpay expects the amount in the smallest unit (e.g., paise for INR)
35     amount_in_paise = int(amount_in_rupees * 100)
36
37     data = {

```

```

38         'amount': amount_in_paise,
39         'currency': currency,
40         'receipt': receipt_id,
41         'notes': {
42             'info': 'Test transaction for demo',
43         }
44     }
45
46     print(f"\nAttempting to create order for {amount_in_rupees} {currency}...")
47
48     try:
49         # Send the request to Razorpay
50         razorpay_order = client.order.create(data=data)
51
52         # Return the essential details
53         print("Order Creation Successful.")
54         print(f"Order ID: {razorpay_order['id']}")
55         return razorpay_order
56
57     except razorpay.errors.RazorpayError as e:
58         print(f"Razorpay API Error during Order Creation: {e}")
59         return None
60     except Exception as e:
61         print(f"An unexpected error occurred: {e}")
62         return None
63
64 # --- 3. PAYMENT VERIFICATION FUNCTION (Backend Webhook/Callback) ---
65 def verify_payment_signature(payment_data):
66     """
67     Verifies the payment signature returned by the Razorpay Checkout,
68     ensuring the payment is authentic and untampered.
69
70     :param payment_data: A dictionary containing 'razorpay_payment_id',
71     | | | | | 'razorpay_order_id', and 'razorpay_signature'
72     :return: True if verification is successful, False otherwise
73     """

```

```

74 # Extract data from the response received from the frontend/webhook
75 order_id = payment_data.get('razorpay_order_id')
76 payment_id = payment_data.get('razorpay_payment_id')
77 signature = payment_data.get('razorpay_signature')
78
79 if not all([order_id, payment_id, signature]):
80     print("Missing payment data for verification.")
81     return False
82
83 print(f"\nVerifying payment {payment_id} for order {order_id}...")
84
85 try:
86     # Use the Razorpay SDK's built-in verification utility
87     # This method automatically uses the KEY_SECRET for HMAC calculation
88     client.utility.verify_payment_signature(payment_data)
89
90     # If no exception is raised, the signature is valid.
91     print("Verification SUCCESS: Payment Signature is valid.")
92     return True
93
94 except razorpay.errors.SignatureVerificationError as e:
95     print(f"Verification FAILED: Signature is invalid. Error: {e}")
96     return False
97
98 # --- 4. EXECUTION EXAMPLE ---
99 if __name__ == '__main__':
100     # --- Step A: Create the Order ---
101
102     # 1. Define the amount
103     item_price = 499.50 # e.g., a product costs ₹499.50
104
105     # 2. Call the order creation function
106     new_order = create_razorpay_order(item_price, receipt_id="receipt_007")
107
108     if new_order:

```

```

74 # Extract data from the response received from the frontend/webhook
75 order_id = payment_data.get('razorpay_order_id')
76 payment_id = payment_data.get('razorpay_payment_id')
77 signature = payment_data.get('razorpay_signature')
78
79 if not all([order_id, payment_id, signature]):
80     print("Missing payment data for verification.")
81     return False
82
83 print(f"\nVerifying payment {payment_id} for order {order_id}...")
84
85 try:
86     # Use the Razorpay SDK's built-in verification utility
87     # This method automatically uses the KEY_SECRET for HMAC calculation
88     client.utility.verify_payment_signature(payment_data)
89
90     # If no exception is raised, the signature is valid.
91     print("Verification SUCCESS: Payment Signature is valid.")
92     return True
93
94 except razorpay.errors.SignatureVerificationError as e:
95     print(f"Verification FAILED: Signature is invalid. Error: {e}")
96     return False
97
98 # --- 4. EXECUTION EXAMPLE ---
99 if __name__ == '__main__':
100     # --- Step A: Create the Order ---
101
102     # 1. Define the amount
103     item_price = 499.50 # e.g., a product costs ₹499.50
104
105     # 2. Call the order creation function
106     new_order = create_razorpay_order(item_price, receipt_id="receipt_007")
107
108     if new_order:

```

```

107
108     if new_order:
109         print("\n--- NEXT STEP ---")
110         print("You would now pass the following to your FRONTEND (e.g., Jinja/React template):")
111         print(f"1. Key ID: {KEY_ID}")
112         print(f"2. Order ID: {new_order['id']}")
113         print(f"3. Amount: {new_order['amount']} (in paise)")
114         print("The frontend uses these to open the Razorpay Checkout form.")
115     else:
116         print("\nOrder creation failed. Cannot proceed with checkout.")
117
118
119     print("\n" + "="*50 + "\n")
120
121     # --- Step B: Verify the Payment (Simulated Callback) ---
122
123     # 1. Simulate the data received from the successful frontend payment/callback.
124     # Note: These IDs and the signature are placeholders and will fail verification!
125     # A real test requires a live successful transaction.
126     simulated_payment_data = {
127         'razorpay_payment_id': 'pay_SimulatedPaymentId123',
128         'razorpay_order_id': 'order_SimulatedOrderId123', # Use a real ID if testing fully
129         'razorpay_signature': 'fakesignatureforillustrationpurposesonly',
130         # In a real scenario, 'razorpay_order_id' must match the ID created in Step A.
131     }
132
133     # 2. Call the verification function
134     # NOTE: This call will fail unless you use real data from a successful test transaction.
135     verification_status = verify_payment_signature(simulated_payment_data)
136
137     if verification_status:
138         print("\nPayment successful and verified! Fulfill the customer's order.")
139     else:
140         print("\nPayment failed verification. DO NOT fulfill the order.")

```

OUTPUT:

```

Razorpay Client Initialized.

Attempting to create order for 499.5 INR...
Order Creation Successful.
Order ID: order_XXXXXXXXXXXXXXXXXXXX <-- This will be a unique ID generated by Razorpay
| | | | | | | | | | (e.g., order_NHfWnUe36oV4iW)

--- NEXT STEP ---
You would now pass the following to your FRONTEND (e.g., Jinja/React template):
1. Key ID: YOUR_KEY_ID
2. Order ID: order_XXXXXXXXXXXXXXXXXXXX
3. Amount: 49950 (in paise)
The frontend uses these to open the Razorpay Checkout form.

=====

Verifying payment pay_SimulatedPaymentId123 for order order_SimulatedOrderId123...
Verification FAILED: Signature is invalid. Error: Signature Verification failed
!!! Note: The actual error message might vary slightly but confirms failure.

Payment failed verification. DO NOT fulfill the order.

```

OBSERVATION :

1. The code creates orders and verifies payments correctly using the Razorpay SDK.
2. API keys are hardcoded, which is insecure—environment variables should be used.
3. Verification will fail because the payment data is only a dummy example.
4. There is a typo: `_name_` should be `__name__`.
5. Overall logic is correct but needs better security and a small syntax fix.

QUESTION 2:

PROMPT :

Show how to store credentials securely using environment variables with example code, and briefly compare this approach with storing credentials in a database or directly in the codebase.

CODE GENERATED :

env.py > ...

```
1 # =====
2 # Method 1: Using python-dotenv (Recommended)
3 # =====
4 # First install: pip install python-dotenv
5
6 import os
7 from dotenv import load_dotenv
8
9 # Load environment variables from .env file
10 load_dotenv()
11
12 # Retrieve credentials from environment variables
13 DB_HOST = os.getenv('DB_HOST')
14 DB_PORT = os.getenv('DB_PORT', '5432') # Default value if not set
15 DB_NAME = os.getenv('DB_NAME')
16 DB_USER = os.getenv('DB_USER')
17 DB_PASSWORD = os.getenv('DB_PASSWORD')
18 API_KEY = os.getenv('API_KEY')
19 SECRET_KEY = os.getenv('SECRET_KEY')
20
21 print(f"Database Host: {DB_HOST}")
22 print(f"Database Name: {DB_NAME}")
23 print(f"API Key: {'*' * 10 if API_KEY else 'Not Set'}") # Masked for security
24
25 # =====
26 # Method 2: Direct OS environment variables
27 # =====
28 # Set in terminal before running:
29 # export DB_PASSWORD="mypassword"
30 # or on Windows: set DB_PASSWORD=mypassword
31
32 DATABASE_URL = os.environ.get('DATABASE_URL')
33 # Use os.environ['KEY'] if you want it to raise error when missing
34 # Use os.environ.get('KEY') for optional with None default
35 # Use os.environ.get('KEY', 'default') for custom default
36
37 # =====
```

env.py > _

```
40 def connect_to_database():
41     """Connect to database using environment variables"""
42     # Example with psycopg2 (PostgreSQL)
43     # pip install psycopg2-binary
44
45     try:
46         import psycopg2
47
48         connection = psycopg2.connect(
49             host=os.getenv('DB_HOST', 'localhost'),
50             port=os.getenv('DB_PORT', '5432'),
51             database=os.getenv('DB_NAME'),
52             user=os.getenv('DB_USER'),
53             password=os.getenv('DB_PASSWORD')
54         )
55
56         print("✓ Database connection successful!")
57         return connection
58
59     except ImportError:
60         print("psycopg2 not installed. Install with: pip install psycopg2-binary")
61     except Exception as e:
62         print(f"✗ Database connection failed: {e}")
63         return None
64
65     # =====
66     # Practical Example: API Request with Auth
67     # =====
68     def make_api_request(endpoint):
69         """Make API request using API key from environment"""
70         import requests
71
72         api_key = os.getenv('API_KEY')
73         base_url = os.getenv('API_BASE_URL', 'https://api.example.com')
74
75         if not api_key:
76             raise ValueError("API_KEY environment variable is not set!")
```

```

77
78     headers = {
79         'Authorization': f'Bearer {api_key}',
80         'Content-Type': 'application/json'
81     }
82
83     try:
84         response = requests.get(f"{base_url}/{endpoint}", headers=headers)
85         response.raise_for_status()
86         return response.json()
87     except requests.exceptions.RequestException as e:
88         print(f"API request failed: {e}")
89         return None
90
91 # =====
92 # Validation: Check Required Variables
93 # =====
94 def validate_environment():
95     """Ensure all required environment variables are set"""
96     required = ['DB_HOST', 'DB_NAME', 'DB_USER', 'DB_PASSWORD', 'API_KEY']
97     missing = [var for var in required if not os.getenv(var)]
98
99     if missing:
100         print(f"⚠ Missing environment variables: {' '.join(missing)}")
101         return False
102
103     print("✓ All required environment variables are set")
104     return True
105
106 # =====
107 # Main Execution
108 # =====
109 if __name__ == "__main__":
110     print("=" * 50)
111     print("Environment Variables Demo")
112     print("=" * 50)

```

```

env.py > -
111     print("Environment Variables Demo")
112     print("=" * 50)
113
114     # Validate environment
115     if validate_environment():
116         # Try database connection
117         conn = connect_to_database()
118         if conn:
119             conn.close()
120     else:
121         print("\nPlease set the required environment variables in your .env file")
122         print(f"or export them in your terminal.")

```

OUTPUT :

```
Desktop/f.html/ai.ass/env.py
Database Host: None
Database Name: None
API Key: Not Set

=====
Environment Variables Demo
=====
⚠Missing environment variables: DB_HOST, DB_NAME, DB_USER, DB_PASSWORD, API_KEY

Please set the required environment variables in your .env file
or export them in your terminal.
```

OBSERVATION:

- Environment variables were not detected — all values like DB_HOST, DB_NAME, DB_USER, DB_PASSWORD, and API_KEY returned None or Not Set.
- The .env file was not loaded or did not contain these variables, so the script could not read any credentials.
- Validation function worked correctly and identified all missing environment variables.
- Because of missing variables, database connection was not attempted, preventing errors.
- The script displayed a clear message instructing the user to set environment variables in a .env file or through the terminal.
- Overall, the program executed exactly as expected and safely handled incomplete configuration

Storing Credentials in Database vs Codebase

Storing in Database

- Credentials can be encrypted before saving.
- Only authorized services/users can access them.
- Supports rotation (you can update keys without changing code).
- Requires an extra DB call, so slightly slower.
- If the DB is hacked and encryption is weak, secrets may leak.

Storing in Codebase

- Very easy but **highly insecure**.

- Anyone with code access can see your credentials.
- Gets uploaded to GitHub by mistake easily.
- Hard to change— you must edit code and redeploy.
- Not recommended for any real project.